Securing Client Identity with Post-Quantum Cryptography

Here's a quick tutorial on how to build a secure, real world client-server model that establishes client identity by using CRYSTALS-Dilithium, a post-quantum cryptography algorithm.

Encryption relies on mathematics to safeguard sensitive electronic information, such as websites and emails. Public-key encryption systems, which are widely used today, depend on mathematical problems that are computationally intractable, ensuring that websites and messages remain inaccessible to unauthorised third parties.

When developing new standards, NIST (National Institute of Standards and Technology) in the US evaluates not only the security of the algorithms' underlying the mathematics but also their most effective applications. The latest standards are designed to address two essential cryptographic tasks:

- General encryption – protecting information exchanged across public networks.
- Digital signatures – providing identity authentication.

In 2022, NIST announced the selection of four algorithms for standardisation: CRYSTALS-Kyber, CRYSTALS-Dilithium, SPHINCS+, and FALCON. Draft standards for three of these were released in 2023, while the fourth — based on FALCON — was released in late 2024.

This article focuses on building a secure, real world client-server model that establishes client identity using CRYSTALS-Dilithium, a post-quantum cryptography (PQC) algorithm finalised by NIST as the primary standard for digital signatures. The algorithm has been standardised as ML-DSA (Module Lattice-Based Digital Signature Algorithm).

Traditional software that relies on RSA or ECC is now being replaced by PQC standards like Dilithium. This standard has numerous advantages.

- ***Quantum resistance:*** Unlike RSA and ECC, which are vulnerable to quantum attacks, Dilithium resists all known quantum algorithms. Developers adopting CRYSTALS-Dilithium can ensure long-term system integrity and non-repudiation.
- ***Compact and secure signatures:*** To reduce signature size while maintaining deterministic behaviour, Dilithium employs a rejection sampling technique. Only signatures within specific bounds are accepted, ensuring both security and efficiency.
- ***Efficiency in constrained environments:*** Despite being lattice-based, Dilithium is computationally efficient. On microcontrollers such as the ARM Cortex-M4, it can sign messages in under 6 million cycles while using less than 8KB of RAM.